

Revamping Password Policy Strategies: Embracing Modern Approaches

Nayara Sangiorgio

© 2026 Gartner, Inc. and/or its affiliates. All rights reserved. Gartner is a registered trademark of Gartner, Inc. and its affiliates. This publication may not be reproduced or distributed in any form without Gartner's prior written permission. It consists of the opinions of Gartner's research organization, which should not be construed as statements of fact. While the information contained in this publication has been obtained from sources believed to be reliable, Gartner disclaims all warranties as to the accuracy, completeness or adequacy of such information. Although Gartner research may address legal and financial issues, Gartner does not provide legal or investment advice and its research should not be construed or used as such. Your access and use of this publication are governed by [Gartner's Usage Policy](#). Gartner prides itself on its reputation for independence and objectivity. Its research is produced independently by its research organization without input or influence from any third party. For further information, see ["Guiding Principles on Independence and Objectivity."](#)

Gartner®

Do Not Rely Solely on Passwords to Protect Corporate Assets



More than

2.8 billion

passwords — hashed or otherwise — were posted for sale (or free for the taking) in criminal forums in 2024.

Source: [2025 Data Breach Investigations Report](#), Verizon

How Do Attackers Discover Passwords?

Brute force

Automated guessing of many passwords until the right one is found.

Password spraying

The attacker tries one or two common passwords across many accounts.

Social engineering

Deceiving people into revealing their passwords, rather than using technical means.

Shoulder surfing

An attacker observes someone as they enter their password.

Key logging

Using a keylogger to capture when a user enters a password.

Manual guessing

Leveraging known personal information to try and guess a password.

Data breach

Using passwords from data leaks to compromise accounts.

Password interception

Passwords can be intercepted as they travel over the network.

Key Issues

1

The human factor: why people break password rules?

2

What's the relevance of passwords in a modern world?

3

Prioritize minimum effective friction.



**When Security Clashes
With Real World Needs,
Guess Who Wins?**

**It isn't always
security.**

Expand SSO Implementation to Simplify User Access and Cut Down on Passwords

Enter credentials for application “A”

Enter credentials for application “B”

Enter credentials for application “D”

Enter credentials for application “C”

Address the Use of Workforce Password Management Tools



Password generation

Generate a unique and random password for each account.



Password vaulting

Store passwords at rest and in an encrypted format.



Password autofill

Fetch passwords stored in the vault and autofill into the corresponding login form fields.

WPM Is Not PAM



Privileged access management

PAM tools are designed
to secure access to
privileged accounts.

Key Issue Take-Away:

Reduce users' cognitive burden by implementing technical solutions that decrease the number of passwords they manage or simplify the password management process.

Key Issues

1

The human factor: why people break password rules?

2

What's the relevance of passwords in a modern world?

3

Prioritize minimum effective friction.

What Should You Do When You're Still Using Passwords as a Factor of MFA or on Their Own?

1

Do not enforce password complexity requirements.

2

Do not enforce password aging requirements.

3

Use technical compensating controls.

What Should You Do When You're Still Using Passwords as a Factor of MFA or on Their Own?

1

Do not enforce password complexity requirements.

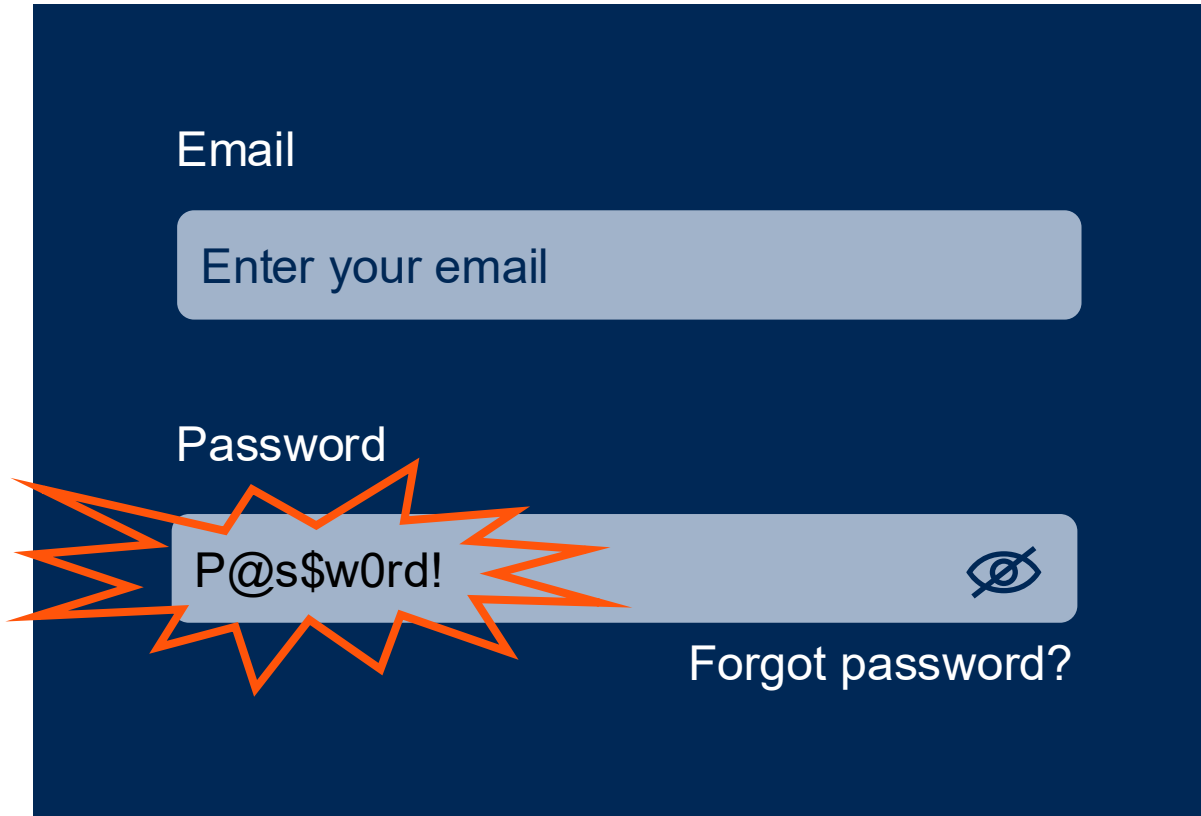
2

Do not enforce password aging requirements.

3

Use technical compensating controls.

Complexity Requirements Have No Clear Benefit for Security



Email

Enter your email

Password

P@s\$w0rd!

Forgot password?

- ✓ Minimum 8 characters
- ✓ Uppercase and lowercase letters
- ✓ At least one special character
- ✓ At least one number

Passwords Can Be Both “Complex” and Predictable

Findings from the U.S. Department of the Interior’s review of its password rules:



99% of the accounts they cracked met their complexity rules.



The **most reused password** (Password-1234) was used on 478 unique active accounts.

Source: [P@s\\$w0rds at the U.S. Department of the Interior: Easily Cracked Passwords, Lack of Multifactor Authentication, and Other Failures Put Critical DOI Systems at Risk](#), U.S. Department of the Interior

Encourage People to Create Longer But Simpler Passwords (or “Passphrases”)

Common (obvious) examples

WelcometotheHotelCalifornia
HarryPotterandtheChamberofSecrets

Dictionary words (less common) examples

AppleRiverDinosaurFerrari
SongParkCountryOcean

What Should You Do When You're Still Using Passwords as a Factor of MFA or on Their Own?

1

Do not enforce password complexity requirements.

2

Do not enforce password aging requirements.

3

Use technical compensating controls.

Regular Forced Password Changes Have No Clear Benefits for Security

Here's why:

Users might use slight variations of old passwords (e.g., Password1 to Password2), reducing overall security.

Attackers **do not wait** around to use **stolen passwords** and typically exploit them **immediately**.

Typical regular password change periods (e.g., 90 days) are long enough to allow sufficient time for an attacker to cause **damage** until the next password rotation.

Regular Forced Password Changes Have No Clear Benefits for Security **and UX**

Here's why:

Frequent changes can lead to **poorer password choices**, lockouts, increased help desk calls, and people feeling overwhelmed and frustrated.

Regular changes can be **disruptive to productivity** due to the time spent on changing or recovering forgotten passwords.

From an accessibility perspective, frequent password changes can disproportionally **affect user with memory or cognitive challenges**.

Regular Forced Password Changes Have No Benefits for Security

Password Aging Can Burden an Already-Weak Authentication Method



Save



Share



Download



Print



Analytics

ARCHIVED

30 March 2005



GO0126336 - 9 min read

By Ant Allar

What Should You Do When You're Still Using Passwords as a Factor of MFA or on Their Own?

1

Do not enforce password complexity requirements.

2

Do not enforce password aging requirements.

3

Use technical compensating controls.

MFA Is an Essential Safeguard, Not an Add-On

According to a study by Microsoft, MFA leads to:

Reduction in the risk of compromise across the entire population

98.56%

99.22%

Reduction even in cases where credentials have been leaked

Source: [How Effective Is Multifactor Authentication at Deterring Cyberattacks?](#) Microsoft

Implement Technical Solutions as Compensating Controls



Active monitoring (detection and response) for unusual logins and user behavior



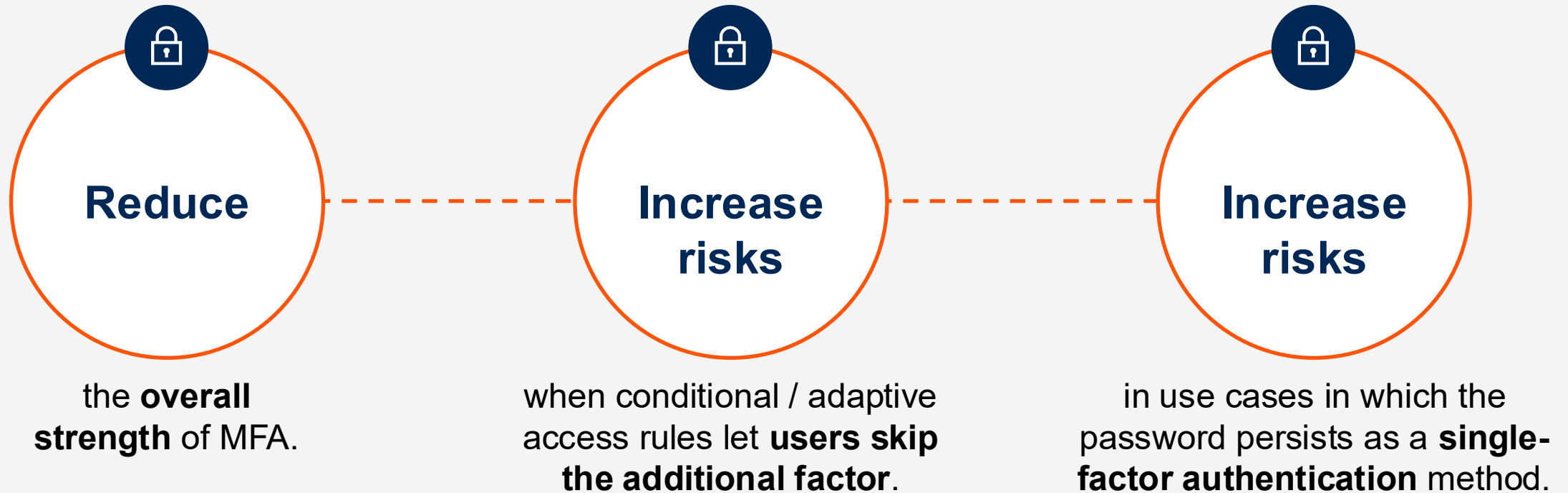
Active monitoring for signs of password compromise



Leverage **password blocklisting** to help prevent the use of weak passwords.

Do Not Relax Rules for Passwords as an Element of MFA

When passwords are used as an element of MFA, reducing password strength would:



**Do not expect passwords to bear
a **heavier** burden than they can.**



Key Issue Take-Away:

Password complexity and aging rules can backfire — prioritize effective technical controls instead.

Key Issues

1

The human factor: why people break password rules?

2

What's the relevance of passwords in a modern world?

3

Prioritize minimum effective friction.



**Make it easy for
people to **know**
what to do.**



**Make it easy for
people to **do** it.**

Key Issue Take-Away:

Modern password policies should set realistic guidelines to protect your organization without slowing people down.

Recommendations

- ✓ **Implement** technical solutions to simplify password management and reduce the number of passwords users need to manage.
- ✓ **Review** and update existing password policies to align with modern best practices, utilizing technical controls to enhance security where appropriate.
- ✓ **Adopt** an adaptive authentication approach to minimize unnecessary friction and invest in passwordless solutions, wherever possible, to reduce the organization's dependence on passwords.

Recommended Gartner Research

To learn more about access to Gartner research, expert analyst insight, and peer communities, contact your Gartner representative or click on “Become A Client” on gartner.com to speak with one of our specialists.

🔍 **[How to Craft a Simple, Effective Password Policy](#)**

Shubham Gera, Nayara Sangiorgio and Ant Allan

🔍 **[Take a Human-Centric Approach to IAM Controls](#)**

James Hoover and Nayara Sangiorgio

🔍 **[Buyer’s Guide for Workforce Password Management Tools](#)**

Nayara Sangiorgio

🔍 **[Magic Quadrant for Privileged Access Management](#)**

Abhyuday Data, Michael Kelley and Others